

KPTC Scheduler

現行アプリケーション仕様書

正式ログイン、4種のセッション権限、内部・外部JSON連携を反映した As-Is 仕様

4 セッション権限	2 分離配布物	3か月 公開データ期間
--------------	------------	----------------

文書版 v3.0 | 更新日 2026-08-16 | 実装基準コミット 83577b6 | ブランチ agent/secure-json-delivery-auth

01 文書の目的・ 現行版の識別

本資料は、2026年8月16日時点でリポジトリとさくらインターネットへ反映されているKPTC Schedulerの実装仕様を固定化するものです。将来構想ではなく、コードで確認できる現行挙動を記載します。

項目	現行版	備考
アプリケーション名	KPTC Scheduler	旧名称 Group Watcher から変更済み
内部URL	https://apfelrunner.sakura.ne.jp/GW/schedule	ログイン必須。ゲスト入口あり
外部URL	https://apfelrunner.sakura.ne.jp/GW/calendar	room=m6 / m7 / m8で対象室を切替
実装基準	83577b6 / agent/secure-json-delivery-auth	本PDF更新直前の機能コミット
技術構成	Vite 8 / React 19 / TypeScript / PHP / SQLite	Node.jsは開発・ビルド時のみ
配布物	dist-internal / dist-public	許可リストで完全分離
保存方式	内部SQLite + 外部単一JSON	公開側にDBと過去月履歴を置かない

今回の主要な更新点

- 利用者選択式デモログインを廃止し、アカウントID・パスワード認証とゲストログインを実装。
- ユーザー管理とログイン管理を統合し、管理者・一般・試験室の権限を同じ編集画面で設定。
- パスワードのアプリケーション上の文字数制限を撤廃し、空文字もハッシュ保存・照合。
- 内部から外部へ署名付きHTTPS JSONを送信し、外部で検証・原子的置換・監視。
- URLを /GW/schedule と /GW/calendar に分離し、空き状況リンクは環境設定で変更可能。

02 システム全体構成と境界

社内利用者 管理者 / 一般 / 閲覧者	内部サーバー React画面 + PHP API 認証DB + SQLite	HTTPS JSON送信 HMAC-SHA256 再送・監視	外部サーバー 受信API + 単一JSON 空き状況画面	一般閲覧者 3室・3か月 ログイン不要
-------------------------	--	--------------------------------------	------------------------------------	---------------------------

領域	保持データ	接続・公開範囲
内部画面	予定、ユーザー、予定種別、操作履歴、認証セッション	社内利用を想定。現行デモURLはインターネット上
内部API	共有状態の読書き、認証、CSRF、競合検知、JSON送信状態	ブラウザとCLIから利用。外部公開ページは接続しない
内部SQLite	app_state、audit_logs、app_meta、auth_users、auth_login_attempts	Web公開領域外。外部から直接接続しない
外部受信API	署名付き3か月JSONだけを受信	内部から外部へのHTTPS POSTのみ
外部JSON	室ID、日付、4状態、更新番号、対象期間	利用者名、件名、メモ、履歴を含まない
外部画面	公開JSONの読取結果	ログイン不要。内部DB・内部APIへ接続しない

境界原則: 外部サーバーから内部DBへの接続経路は作りません。内部側が公開可能な情報だけを生成し、外部側へ押し出します。

03 ログイン・セッション・権限

権限 / 入口	閲覧	予定の追加・編集・移動・コピー・削除	ユーザー・予定種別管理	履歴・取り消し
管理者 (admin)	可	可	可	閲覧・取り消し可
一般 (user)	可	可	不可	不可
試験室 (room)	可	不可	不可	不可
ゲスト (guest)	可	不可	不可	不可

ログイン画面

- ユーザープルダウンには、有効な管理者・一般アカウントだけを氏名と権限付きで表示。試験室アカウントは表示しない。
- 選択したアカウントのパスワードを入力してログイン。空パスワードの場合は未入力のまま送信可能。
- 「ゲストとしてログイン」はパスワード不要。予定の閲覧だけを許可。
- 画面で操作を隠すだけでなく、更新APIでもguest / roomをHTTP 403で拒否。一般によるユーザー・予定種別変更も拒否。

セッション既定値

項目	既定値 / 動作
Cookie名	KPTC_SCHEDULER_SESSION
Cookie属性	Secure設定可 / HttpOnly / SameSite=Strict / 配置パス単位
アイドル期限	1,800秒 (30分)。KPTC_AUTH_IDLE_TIMEOUTで変更
絶対期限	43,200秒 (12時間)。KPTC_AUTH_ABSOLUTE_TIMEOUTで変更
更新防御	ログイン済みセッション + X-CSRF-Token
権限変更	auth_revision更新により既存セッションを無効化

04 パスワード・アカウント管理仕様

機能	仕様
アカウントID	3-64文字。半角英数字で開始し、英数字・ピリオド・アンダースコア・@・ハイフンを使用。大文字は小文字へ正規化
パスワード長	アプリケーション上の最小・最大文字数制限なし。0文字も有効
保存	平文を保存しない。SHA-512で固定長化後、Argon2id対応時はArgon2id、それ以外はPHP推奨方式で適応的ハッシュ化
旧ハッシュ互換	旧方式でも照合し、ログイン成功時に新方式へ自動再ハッシュ
変更	既存ユーザーでは「パスワードを変更する」を明示選択。未選択なら現行ハッシュを維持。空欄を選択保存するとパスワードなしへ変更
試行制限	同一ユーザー名・接続元で5回失敗すると15分間制限
秘匿	ハッシュを管理画面・API応答・操作履歴へ返さない

運用上の注意: 空パスワードは仕様上利用できますが、一般権限でも予定を変更できます。本番環境ではネットワーク制限と十分なパスワード設定を推奨します。

ユーザーとアカウントの統合編集

- 管理者は氏名、表示文字、表示色、所属、内線、権限、アカウントID、パスワードを1画面で保存。
- 所属は「電気通信係」「試験室」の2種類。試験室権限でログイン不要の場合のみアカウントIDを空欄にできる。
- ユーザー削除時は紐づく認証アカウントと予定も同一トランザクションで削除。ログイン中ユーザーは削除不可。
- 最後の有効な管理者は降格不可。アカウントID重複はHTTP 409。

05 画面一覧・ナビゲーション

ID	画面 / セクション	利用者	主な機能 / 入口
SCR-01	ログイン	全員	管理者・一般の選択式ログイン、ゲストログイン //GW/schedule
SCR-02	スケジュール	全権限	日・週・月表示、グループ絞込、検索。編集操作は権限に従う
SCR-03	ユーザー・予定種別	管理者	統合ユーザー・アカウント管理、表示順、予定種別管理
SCR-04	操作履歴	管理者	変更者、内容、日時、取り消し可否
SCR-05	電波暗室 空き状況	一般公開	/GW/calendar?room=m6
SCR-06	電磁波妨害評価装置(G-TEM)	一般公開	/GW/calendar?room=m7
SCR-07	パルスサージシステム	一般公開	/GW/calendar?room=m8

レスポンス表示

- デスクトップは左ナビゲーションと上部ツールバー。週表示は月曜から日曜まで7列を表示。
- 小画面では下部ナビゲーションへ切替え、予定表は必要に応じて横スクロール。
- 長いメンバー名・試験室名は折り返し、予定ブロックは最小高さ40.5px。
- 試験室空き状況リンクは新しいタブで開き、KPTC_PUBLIC_AVAILABILITY_PAGE_URLを優先。

06 スケジュール表示仕様

機能ID	機能	仕様
CAL-01	初期表示	実行時の現在日を含む週
CAL-02	日表示	選択日の対象ユーザーを行単位で表示。前後ボタンは1日移動
CAL-03	週表示	月曜始まり、月曜日から日曜日まで7日。前後ボタンは7日移動
CAL-04	月表示	月曜始まり42セル。1日最大4件と残件数。前後ボタンは1か月移動
CAL-05	当日へ戻る	日=今日、週=今週、月=今月
CAL-06	グループ	すべてのグループ / 電気通信係 / 試験室
CAL-07	検索	ユーザー名と所属の部分一致
CAL-08	休日	土曜は青系、日曜・2026年/2027年の国民の祝日は赤系
CAL-09	複数日	開始日から終了日まで各日に同じ予定を表示
CAL-10	予定カード	時刻、件名、種別色、複数日、メモ、非公開、選択状態

日付演算はAsia/Tokyoの正午基準、日付キーはYYYY-MM-DDです。タイムゾーン境界による日ずれを避けます。

07 予定の登録・編集・複数操作

入力項目	仕様
件名	必須
ユーザー	全登録ユーザーから選択。他ユーザー・試験室の予定も一般以上が変更可能
予定種別	休暇 / 機器点検 / 機器利用 / キャンセル待ち / 所内会議 / 出張・外出 / その他
開始日・終了日	終了日は開始日以降。複数日予定に対応
時間帯	時間指定 / 終日(00:00-23:59) / 午前(09:00-12:00) / 午後(13:00-17:00)
メモ	任意。予定カードに印を表示
非公開	印を表示。現行実装は件名・時刻・メモを秘匿しない

操作入口

操作	マウス / キーボード
新規	追加ボタン、日付欄ダブルクリック、日付欄右クリック「新規予定作成」
編集	予定ダブルクリック、単一選択後Enter
移動	予定を他の日付・他ユーザーへドラッグ&ドロップ
複数選択	Shift+クリック。Shiftなしで別予定・日付をクリック、またはEscで解除
コピー・切り取り	右クリック、Ctrl/Cmd+C、複数選択対応
貼り付け	日付欄右クリック、Ctrl/Cmd+V。複数予定は基準日との差を保って貼付
削除	右クリック、Delete / Backspace、編集画面。確認後に複数削除可

08 共有保存・競合・操作履歴

機能	仕様
自動保存	予定変更後に短時間まとめ、SharedState全体を直列保存
楽観ロック	クライアントのversionとDBのversionを比較。不一致はHTTP 409と最新状態を返す
トランザクション	状態、認証関連変更、監査ログをSQLiteトランザクションで整合
操作履歴	変更者ID・氏名、操作名、概要、変更前後JSON、日時を記録
取り消し	管理者のみ。before_jsonを新versionとして復元し、取り消し自体も履歴化
公開連携	内部保存を先に確定。JSON送信失敗でも予定保存を取り消さず再送待ちへ
オフライン	内部APIへ接続できない場合はオフライン表示。未保存変更の永続的な後送は行わない

内部SQLite主要テーブル

テーブル	役割
app_state	members / schedules / categoriesをJSON 1行とversionで保持
audit_logs	操作履歴、変更前後、取り消し状態
app_meta	移行済みフラグ、JSON送信状態、最終成功・失敗情報
auth_users	アカウントID、member_id、ハッシュ、権限、有効状態、認証リビジョン
auth_login_attempts	ログイン失敗回数制限

09 試験室空き状況の生成・表示

対象	室ID	公開名称 / 補足	
電波暗室	m6	電波暗室 空き状況	
電材室相当	m7	電磁波妨害評価装置(G-TEM) 空き状況	
電子情報研究室相当	m8	パルスサージシステム 空き状況 / 試験機副題あり	
内部予定		公開状態	画面表示
機器点検		maintenance	日付を表示せず「-」
機器利用 / キャンセル待ちが9:00-12:00だけ		afternoon_available	日付を表示せず「▼」 = 午後空きあり
機器利用 / キャンセル待ちが13:00-17:00だけ		morning_available	日付を表示せず「▲」 = 午前空きあり
午前・ 午後の両方		reserved	記号なし。濃い灰色で予約済み
該当予定なし		JSONの日別項目なし	日付を表示して予約可

- 当月を含む直近3か月をAsia/Tokyoで生成。公開側は単一JSONを置換し、過去月履歴を残さない。
- 土曜は青、日曜・祝日は赤。営業日が全て予約済みまたは点検なら月全体へ「予約済み(キャンセル待ち)」を重ねる。
- 公開ページには予約・問い合わせ文、利用時の連絡注意、技術センターロゴを表示。

10 内部から外部へのJSON連携

段階	処理
1. 生成	availability-json.phpがm6/m7/m8の3か月状態を生成
2. 検証	キー、schemaVersion=1、sourceVersion、期間、室ID、4状態を契約で検査
3. 署名	timestamp + 改行 + JSON本文を共有鍵でHMAC-SHA256
4. 送信	HTTPS POST。X-KPTC-Timestamp / X-KPTC-Signatureを付与。リダイレクト追従なし
5. 受信	POST、1-131072バイト、時刻差5分以内、署名一致、JSON構造・世代を検証
6. 保存	一時ファイルへ0600で書き、renameでpublic-availability.jsonを原子的置換
7. 再送	失敗時はpendingと回数・エラーを内部DBへ記録。5分timerで再送
8. 監視	内部CLIの終了コード、外部health APIのHTTP 200/503で監視

公開JSONの項目は schemaVersion / sourceVersion / updatedAt / rangeStart / rangeEnd / availability の6項目だけです。

11 API・CLI一覧

入口	認証 / 権限	用途
api.php?action=bootstrap	セッション任意	未認証時はログイン候補、認証時は状態・権限・CSRFを返す
api.php?action=login	POST	アカウントID・パスワード認証
api.php?action=guest-login	POST	閲覧専用ゲストセッション開始
api.php?action=logout	CSRF	セッション破棄
api.php?action=save	管理者 / 一般 + CSRF	予定等の保存。一般のマスタ変更は拒否
api.php?action=member-account	管理者 + CSRF	ユーザーとアカウントの一体保存・削除
api.php?action=undo	管理者 + CSRF	操作取り消し
receive-availability.php	HMAC署名	外部JSON受信
public-availability.php	不要	公開JSON読取
health-availability.php	不要	外部の鮮度・当月確認
publish-availability-cli.php	CLI	最新JSON送信と再送状態記録
monitor-availability-cli.php	CLI	pending・失敗・鮮度を終了コード化
manage-auth-user-cli.php	CLI	初期管理者、一覧、有効化、パスワード変更

12 環境設定・配置

設定	役割 / 既定
KPTC_INTERNAL_SCHEDULER_DB	内部SQLiteの絶対パス
KPTC_PUBLIC_AVAILABILITY_MODE	localまたはhttps。本番分離はhttps
KPTC_PUBLIC_AVAILABILITY_ENDPOINT	外部receive-availability.phpのHTTPS URL
KPTC_PUBLIC_AVAILABILITY_PAGE_URL	内部画面から開く外部カレンダーURL。再ビルド不要
KPTC_PUBLIC_AVAILABILITY_SECRET	内部・外部で共有する32文字以上の秘密値
KPTC_PUBLIC_AVAILABILITY_JSON	外部単一JSONの絶対パス
KPTC_PUBLIC_AVAILABILITY_STALE_SECONDS	監視の鮮度。既定1,800秒、下限600秒
KPTC_SESSION_COOKIE_SECURE	HTTPS Cookieを強制する場合1
KPTC_AUTH_IDLE_TIMEOUT / ABSOLUTE_TIMEOUT	認証セッション期限

現行さくら配置

用途	配置
内部Web	/home/apfelrunner/www/GW/schedule/
外部Web	/home/apfelrunner/www/GW/calendar/
内部DB	/home/apfelrunner/GW/group-watcher.sqlite
内部設定	/home/apfelrunner/GW/config/internal-env.php
外部設定	/home/apfelrunner/GW/config/public-env.php
公開JSON	/home/apfelrunner/GW-public/ 配下

13 非機能・セキュリティ・制約

分類	現行対策	残る注意点
認証	ハッシュ保存、試行制限、期限、セッションID再生成	空パスワードを許容。組織SSOは未連携
認可	サーバー側でadmin / user / room / guestを判定	現行さくらURL自体は外部到達可能
更新	CSRF、POST限定、version競合検知、SQLiteトランザクション	差分マージではなく競合後の再操作が必要
公開連携	HMAC、時刻差、サイズ、スキーマ、世代、原子的置換	共有鍵のローテーション手順は運用で定義
個人情報	公開JSONは室ID・日付・状態だけ	内部DBバックアップはアクセス制限が必要
可用性	送信失敗時再送、内部・外部監視	内部API停止中のオフライン編集・自動後送はない
祝日	2026年・2027年を静的定義	2028年以降はデータ追加が必要

14 検証・受入基準・変更履歴

検査	合格条件
TypeScript	pnpm run checkが成功
回帰テスト	pnpm testの8テストが成功
本番ビルド	dist-internal / dist-publicを生成し、禁止ファイル混入なし
PHP構文	public/*.phpがphp -lで全件成功
認証通信	管理者・一般・ゲスト、空パスワード、長いパスワード、権限拒否を確認
公開通信	署名付き送受信、sourceVersion更新、内部monitor=0、外部health=200
画面	日週月、7日列、権限別ボタン、3室空き状況、モバイル表示を確認

文書改訂履歴

版	日付	主な内容
v2.0	2026-08-15	最小構成、複数予定、3か月JSON分離
v3.0	2026-08-16	正式認証、権限、ゲスト、統合ユーザー管理、任意長パスワード、2配布物、署名送受信、URL分離

本資料とコードに差異がある場合は、実装基準コミット以降のGit履歴を確認し、資料を同時更新してください。